

ALA:3

Name: Parmar Vishva j .
Enrolment No: 240905091015
Course: BET-/IT
Subject: Cloud Computing (BETCE17336)

ALA 3

Cloud Security Analysis (Review Activity): In this activity each student will prepare a review paper on the security features of acloud platform to understand critical aspects of cloud security. They will analyze components such as Identity and Access Management (IAM), encryption techniques, and data protection mechanisms implemented by the platform. The study should include comparative analysis, real-world scenarios, and best practices for securing cloud environments. Students will submit a detailed report or research paper along with proper references, and upload it on the GMIU portal.

Solution

A Comprehensive Review of Cloud Security Architectures: IAM, Cryptographic Mechanisms, and Zero Trust Paradigms

Abstract

Cloud computing has shifted the organizational security perimeter from physical network perimeters to identity- and policy-driven software controls. This paper reviews modern cloud security architectures, focusing on Amazon Web Services (AWS) and Microsoft Azure. We evaluate key structural domains: Identity and Access Management (IAM), cryptographic data protection mechanisms (data at rest and in transit), and cloud threat vectors. Through a comparative architectural analysis and an investigation of real-world security breaches (e.g., Capital One SSRF and IAM role escalation), this paper identifies structural vulnerabilities and establishes best practices based on Zero Trust Network Architecture (ZTNA).

1. Introduction & The Shared Responsibility Model

Cloud adoption introduces a distinct security paradigm governed by the **Shared Responsibility Model**. Security responsibilities vary significantly depending on the cloud service model:

- **Infrastructure as a Service (IaaS):** The Cloud Service Provider (CSP) manages the physical facilities, host virtualization, and hardware infrastructure. The customer assumes full responsibility for guest operating systems, network configuration, access management, applications, and customer data.
- **Platform as a Service (PaaS):** The CSP abstracts the operating system, middleware, and runtime engines. The customer is responsible for application logic, credential integrity, data configurations, and user access policies.
- **Software as a Service (SaaS):** The CSP manages nearly the entire stack. The customer retains critical responsibility for identity management, user permissions, and regulatory compliance of processed data.

Most operational cloud security failures stem not from underlying hypervisor or CSP infrastructure flaws, but from tenant-side misconfigurations, overly permissive privileges, and exposed access keys.

2. Identity and Access Management (IAM)

IAM forms the primary logical boundary in cloud security, providing identity authentication and authorization across human identities and machine workloads.

Principle of Least Privilege (PoLP) and Role-Based Access Control (RBAC)

Cloud access models rely on Role-Based Access Control (RBAC) and Attribute-Based Access Control (ABAC). In least-privilege configurations:

- **Temporary Credentials over Long-Lived Keys:** Static API access keys pose significant credential leakage risks. Workloads rely on temporary tokens (e.g., AWS Security Token Service / Azure Managed Identities) associated with short time-to-live (TTL) expiration windows.
- **Policy Granularity:** Policies must explicitly define explicit allows and implicit denies, specifying precise Actions, Resources, and Condition keys (such as enforcing source IP ranges or Multi-Factor Authentication presence).

3. Data Protection and Cryptographic Techniques

Data at Rest Encryption

- **Cryptographic Algorithms:** Cloud platforms standardize on symmetric Advanced Encryption Standard with 256-bit keys (**AES-256**) in Galois/Counter Mode (GCM) or Cipher Block Chaining (CBC) mode.
- **Envelope Encryption:** To minimize performance overhead when encrypting large volumes, cloud platforms utilize envelope encryption:
    1. Data is encrypted directly using a unique **Data Encryption Key (DEK)**.
    2. The DEK itself is encrypted using a **Key Encryption Key (KEK)** managed within a Hardware Security Module (HSM).
    3. Only the encrypted DEK is stored alongside the ciphertext.

Key Management Services Comparison

- **AWS Key Management Service (KMS):** Uses FIPS 140-2/3 validated HSMs. Supports Customer Managed Keys (CMKs) with automated annual key rotation and detailed AWS CloudTrail audit logs.

- **Azure Key Vault:** Centralizes secrets, certificates, and cryptographic keys backed by managed HSMs, integrating directly with Azure RBAC and Microsoft Entra ID authentication.

Data in Transit

All internal and ingress/egress network flows are protected using **Transport Layer Security (TLS 1.2 / TLS 1.3)** with Ephemeral Diffie-Hellman key exchange (DHE/ECDHE) to ensure Perfect Forward Secrecy (PFS).

4. Comparative Architectural Analysis: AWS vs. Microsoft Azure

Security Vector	Amazon Web Services (AWS)	Microsoft Azure
Identity Management	AWS Identity and Access Management (IAM) & IAM Identity Center	Microsoft Entra ID (formerly Azure Active Directory)
Workload Identity	IAM Roles for EC2 / IRSA for EKS	Azure Managed Identities (System-assigned / User-assigned)
Key & Secret Storage	AWS KMS & AWS Secrets Manager	Azure Key Vault & Dedicated HSM
Network Isolation	Virtual Private Cloud (VPC), Security Groups (Stateful), NACLs (Stateless)	Virtual Network (VNet), Network Security Groups (NSGs), Azure Application Security Groups
Posture & Threat Detection	Amazon GuardDuty (ML anomaly	Microsoft Defender for Cloud, Microsoft Sentinel (SIEM/SOAR)

	detection), AWS Security Hub	
Data Loss Prevention / PII	Amazon Macie (S3 automated PII discovery)	Microsoft Purview Information Protection

5. Real-World Case Study: Capital One Breach (Misconfiguration & Escalation)

- **Attack Vector:** Server-Side Request Forgery (SSRF) combined with an overly permissive IAM role.
- **Vulnerability Analysis:**
  1. Attackers exploited an SSRF vulnerability in an open-source Web Application Firewall (ModSecurity) running on an AWS EC2 instance.
  2. The SSRF allowed the attacker to query the AWS Instance Metadata Service (169.254.169.254/latest/meta-data/iam/security-credentials/) to harvest temporary IAM credentials assigned to the EC2 instance role.
  3. The compromised IAM role had excessive administrative permissions across the account, including s3:ListBuckets and s3:GetObject on sensitive consumer financial databases.
- **Remediation & Industry Impact:**
  - Introduction and mandatory migration to **IMDSv2** (Instance Metadata Service Version 2), which enforces a session-oriented token exchange using PUT requests that SSRF payloads cannot traverse.
  - Rigorous IAM policy boundaries to prevent compute workloads from accessing unneeded storage buckets.

6. Zero Trust Best Practices for Cloud Environments

1. **Enforce MFA and Context-Aware Access:** Mandate phishing-resistant Multi-Factor Authentication (FIDO2/WebAuthn) for administrative consoles and API orchestrations.
2. **Eliminate Hardcoded Secrets:** Transition entirely from persistent developer access keys to IAM Roles, temporary token assumption, and short-lived OIDC federation tokens.
3. **Continuous Auditing & Drift Detection:** Run automated Infrastructure as Code (IaC) linting and cloud security posture management tools (e.g., AWS Config, Azure Policy) to detect open security groups or unencrypted buckets.
4. **Micro-Segmentation:** Implement strict subnet routing, disable public IPv4 assignments on database/application tiers, and restrict administrative access (SSH/RDP) to managed bastion solutions (e.g., AWS Systems Manager Session Manager, Azure Bastion).

7. References

1. Mell, P., & Grance, T. (2011). *The NIST Definition of Cloud Computing*. National Institute of Standards and Technology (NIST) Special Publication 800-145.
2. Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero Trust Architecture*. NIST Special Publication 800-207.
3. Amazon Web Services. (2024). *AWS Security Best Practices: Well-Architected Framework - Security Pillar*. AWS Technical Documentation.
4. Microsoft Corporation. (2024). *Azure Security Benchmark (v3): Best practices and recommendations for cloud security*. Microsoft Learn.
5. Cloud Security Alliance (CSA). (2023). *Top Threats to Cloud Computing: The Pandemic Eleven*. CSA Research Publications.
6. Buyya, R., Broberg, J., & Goscinski, A. (2011). *Cloud Computing: Principles and Paradigms*. John Wiley & Sons.